

Lumi Reading · Security & Privacy Evidence

PR10

Data Sharing Audit

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

PRIVACY/LEGAL-SENSITIVE DRAFT — PRIVACY ADVISER MUST REVIEW

This audit reaches a legal-adjacent conclusion (the PR10 answer). It is a **draft** for the appointed Australian privacy adviser to confirm before the readiness answer is relied on. It does **not** modify any live page and is not legal advice.

ST4S item: PR10 (is user data shared with third parties beyond the permitted cases?) **Version:** 0.1 — DRAFT for review, not yet signed **Date:** 2026-07-24 **Status:** Draft for review — not yet signed **Primary sources:** docs/privacy/VENDOR_DATA_FLOW_REGISTER.md , docs/privacy/PRIVACY_IMPACT_ASSESSMENT.md , the live privacy page (school-admin-web/src/app/legal/privacy/page.tsx)

1. What this audit answers

The readiness question PR10 asks whether Lumi shares user data with third parties **beyond the permitted cases** (consent, legal requirement, or operating the service through a processor). Lumi's current baseline answer is **"Yes"**, which this audit concludes is a **misreading**: using processors such as Google/Firebase to run the service is not "third-party sharing" in the sense PR10 means.

The distinction (from APP_8_CROSS_BORDER_DISCLOSURE_LAWYER_BRIEF.md §2 and OAIC guidance): providing data to a contractor to process **on your instructions, for your purposes** is a *use through a processor*, not a disclosure to an independent third party acting for its own purposes. Lumi does the former; it does not sell, rent, or hand personal information to anyone for that party's own use.

2. Every flow where user data leaves Lumi's systems

Each flow below is classified as a **permitted case** — (C) consent, (L) legal requirement, or (P) service operation via a processor — or as **genuine third-party sharing**. Every row is sourced from the vendor register and PIA.

#	Flow (data leaving Lumi's own code)	Data	Classification	Permitted?
1	Store/serve all records via Firestore	School/child/adult/roster/reading/messaging records	(P) Processor — Google Cloud DPA, AU region	 Permitted

#	Flow (data leaving Lumi's own code)	Data	Classification	Permitted?
2	Media in Cloud Storage	Comprehension audio, logos, covers	(P) Processor — Google Cloud DPA, AU region	✓ Permitted
3	Server logic in Functions / Run / Eventarc / Scheduler	All records, transiently	(P) Processor — AU region	✓ Permitted
4	Cloud Logging	Minimised events (direct identifiers/raw exceptions prohibited); admin identity in required audit logs	(P) Processor — AU ordinary logs; required audit logs global	✓ Permitted
5	Secret Manager	Service credentials only — no child content	(P) Processor — AU-only replica	✓ Permitted (no user PII)
6	Firebase Authentication	Adult UID, email/phone, MFA factors	(P) Processor — US region	✓ Permitted (APP 8 review pending)
7	FCM + APNs push	Device token; adult-facing notification content	(P) Processor — global platform	✓ Permitted
8	Firebase App Check	Device/app attestation token — no content	(P) Processor — global	✓ Permitted (no PII content)
9	Firebase Analytics	Pseudonymous events; no Lumi UID / no child/account identifiers	(C) Adult opt-in, off by default	✓ Permitted (consent)
10	Firebase Crashlytics	Crash stack + device diagnostics; no Lumi UID	(C) Adult opt-in, off by default	✓ Permitted (consent)
11	Twilio SendGrid email	Adult/school transactional content; child data excluded by policy	(P) Processor — NA/EU/US	✓ Permitted (APP 8 review pending)
12	Google Books API lookup	ISBN / title only	(P) Processor — no personal info sent	✓ Permitted (see §3)
13	Open Library / Internet Archive lookup	ISBN / title / work ID only	(P) Processor — no personal info sent	✓ Permitted (see §3)
14	Apple App Store / Google Play	Adult/device account, purchase, store diagnostics	(P/contract) Platform terms	✓ Permitted

#	Flow (data leaving Lumi's own code)	Data	Classification	Permitted?
15	Disclosure within the school community	A child's reading info to that child's teacher/admins and linked parents/carers	Intended in-service disclosure to authorised users (not an external third party)	✅ Permitted
16	Disclosure required by law / to protect safety	As legally compelled	(L) Legal requirement	✅ Permitted (case-by-case)
—	Sale / rental of personal information	—	Does not occur	✅ None
—	Third-party advertising / cross-app tracking	—	Does not occur	✅ None

Basis for the two "does not occur" rows: the live privacy policy states Lumi does **not** sell personal information, does **not** use it for third-party advertising, and does **not** track users across other companies' apps or websites; the vendor register records **no ad SDK** in the app.

3. Book-lookup APIs receive ISBN/title only (confirmed)

The book-metadata lookups (flows 12–13) are the flows most likely to be misread as "sharing", so they are confirmed explicitly:

- The vendor register states the request "includes only ISBN/title" (Google Books) and "only ISBN/title/work ID" (Open Library), with "No identity data intended" for both.
- PIA risk **P-12** requires: "Send only ISBN/title; never include child, school, notes or account identifiers; retain manual entry" — rated Low/Controlled.
- The live privacy policy §4 states: "No student information is sent in these look-ups."
- A manual-entry fallback exists, so the lookup is helpful but replaceable.

Conclusion for §3: book-lookup APIs receive bibliographic identifiers only (ISBN/title/work ID) and **no student or account data**. (*Adviser note: this is asserted from the register/PIA/policy; a source-level confirmation of the request payload — see gaps — would make it evidenced rather than documented.*)

4. Conclusion — the PR10 answer

Every flow in §2 falls into a **permitted case**: service operation via a processor, adult consent (optional diagnostics only), a legal requirement, or an intended in-service disclosure to the child's own authorised school community. **No flow is genuine third-party sharing** — Lumi does not sell personal information, does not use it for advertising, and does not disclose it to any party for that party's own purposes.

PR10 recommended answer: "No — we do not share user data outside the permitted cases." Using processors (Google/Firebase, SendGrid, push platforms) to operate the service is **not** third-party sharing.

Keep this audit as the evidence behind that answer.

5. Evidence index

Claim	Evidence
Full list of egress flows, data, locations	docs/privacy/VENDOR_DATA_FLOW_REGISTER.md
Processor vs disclosure distinction	APP_8_CROSS_BORDER_DISCLOSURE_LAWYER_BRIEF.md §2; OAIC APP 8 guidance
No sale / no ad tracking / no ad SDK	Live privacy page §2; vendor register (Apple/Google row: "No ad SDK")
Book APIs get ISBN/title only	Register (Google Books / Open Library rows); PIA P-12; live privacy page §4
Analytics/Crashlytics opt-in, off by default, no Lumi UID	PIA §2, §4; live privacy page §8
In-school disclosure is role/class/child-scoped	PIA APP 6 note; firebase.rules ; ACCESS_CONTROL_POLICY.md
Companion sub-processor detail	SUB_PROCESSOR_TABLE.md (PR17)

6. Known gaps / adviser must confirm

- **Processor-vs-disclosure characterisation is counsel's call.** This audit applies the OAIC framing operationally; the formal APP 8 disclosure/use determination per flow is **pending counsel** (APP 8 brief §5, §8).
- **US/global processor flows (Firebase Auth, FCM/APNs, SendGrid) still need the APP 8 reasonable-steps sign-off** before "permitted" is legally settled — the classification here is that they are processor flows, not that the cross-border assessment is complete.
- **Book-lookup payload is documented, not yet source-verified.** A quick code confirmation that only ISBN/title is placed on the outbound request would upgrade §3 from "documented" to "evidenced".
- **Cloudflare edge.** If a Cloudflare Worker/CDN sits in front of any user request, edge processing (e.g. IP addresses) is an egress not captured above; confirm scope (see [SUB_PROCESSOR_TABLE.md](#) and [INT7_SUBPROCESSOR_AGREEMENTS_RECORD.md](#)).
- **Support mailbox provider** is unnamed; requests emailed to support leave via that provider — classify once the provider is recorded.
- **Sign-off.** The PR10 answer change to "No" should be confirmed by the privacy adviser and Nic before it is entered in the readiness check.